SIZMA TESTİ RAPORU

Rapor Tarihi	22/10/2026
Hazırlayan	Ömer Faruk Baysal
Test Hedefi	PortSwigger Web Academy Lab

1. Password reset

Bu raporda, PortSwigger Web Security Academy'de yer alan password reset konusuyla ilgili iki durum tek bir bulgu altında ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın parola sıfırlama (password reset) mekanizmasının iki farklı biçimde güvenli olmadığı tespit edilmiştir. Her iki durumda da, kimliği doğrulanmamış bir saldırganın başka bir kullanıcının (carlos) parolasını yetkisiz biçimde sıfırlayarak hesabını ele geçirebildiği gösterilmiştir. İlk durumda sıfırlama isteğindeki kullanıcı adı alanının değiştirilebilmesi, ikinci durumda ise sıfırlama bağlantısının kullanıcı kontrolündeki bir HTTP başlığından (X-Forwarded-Host) oluşturulması zafiyete yol açmaktadır. Yönetici dâhil herhangi bir hesabın ele geçirilmesine imkân tanıdığından, zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Durum 1: Password reset broken logic

Hedef uygulamanın parola sıfırlama akışında, yeni parolanın belirlendiği istekte bir kullanıcı adı (username) alanı yer almakta ve sıfırlama token'ı bu kullanıcıya sıkıca bağlanmamaktadır. Bu nedenle, istekteki kullanıcı adı başka bir kullanıcıyla (carlos) değiştirildiğinde, sunucu token'ın gerçekte hangi kullanıcıya ait olduğunu doğrulamadan o kullanıcının parolasını değiştirmektedir. Böylece saldırgan, herhangi bir kullanıcının parolasını yetkisiz biçimde sıfırlayabilmektedir.

Durum 2: Password reset poisoning via middleware

İlk durumdan farklı olarak, parola sıfırlama e-postasındaki bağlantının alan adı, sunucunun güvendiği ancak istemci kontrolünde olan X-Forwarded-Host HTTP başlığından oluşturulmaktadır. Saldırgan, hedef kullanıcı (carlos) için bir sıfırlama talebi gönderirken bu başlığa kendi kontrolündeki bir sunucu adresini yerleştirdiğinde, kurbana giden e-postadaki bağlantı saldırganın sunucusuna işaret eder ve kurbanın geçerli sıfırlama token'ını taşır. Kurban bu bağlantıya tıkladığında token saldırganın erişim kayıtlarına (access log) düşmekte ve saldırgan bu token ile kurbanın parolasını sıfırlayabilmektedir.

4. Risk Seviyesi

Risk Seviyesi	Kritik
CVSS v3.1 Skoru	9.1
CVSS v3.1 Vektörü	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
CWE	CWE-640 (Weak Password Recovery Mechanism for Forgotten Password)

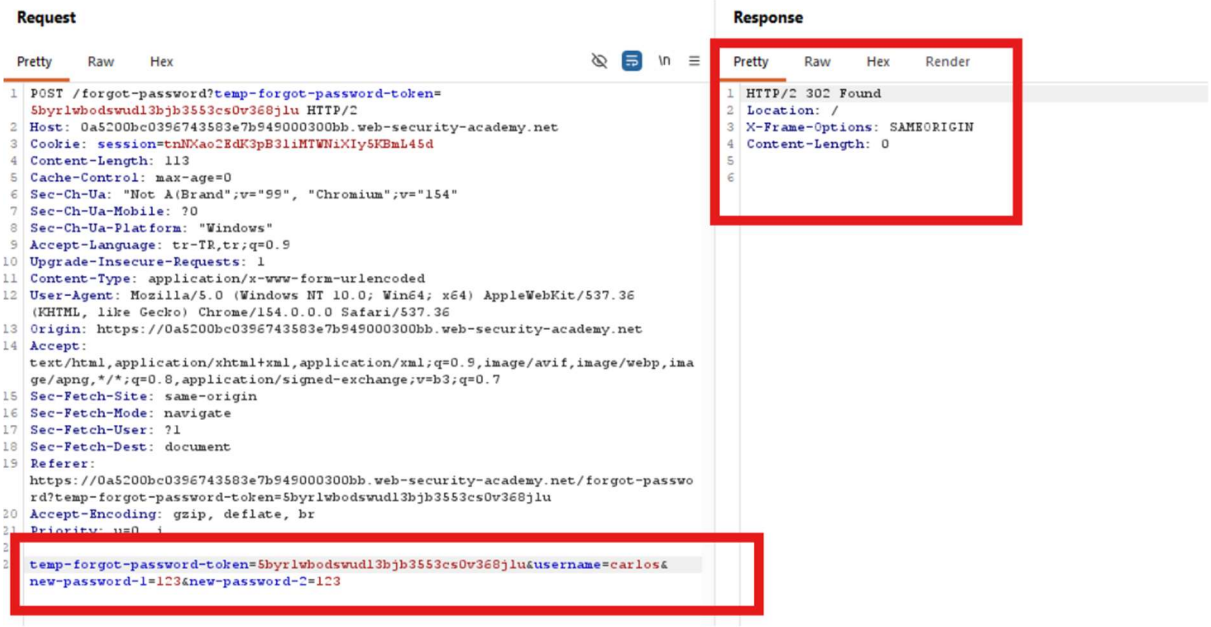
5. Etki

Yapılan testler sonucunda, kimliği doğrulanmamış bir saldırgan, parola sıfırlama mekanizmasındaki zayıflıklardan yararlanarak başka bir kullanıcının parolasını yetkisiz biçimde sıfırlayıp hesabını tamamen ele geçirebilmektedir. Doğrulanan etki, hedef kullanıcının (carlos) parolasının değiştirilerek hesabına tam erişim sağlanmasıdır. Zafiyet herhangi bir kullanıcı için işlediğinden, potansiyel etki yönetici hesapları dâhil tüm hesapların ele geçirilmesi ve bu yolla sistemin tümüyle tehlikeye atılmasıdır. Özellikle birinci durum, herhangi bir kullanıcı etkileşimi gerektirmeden doğrudan sömürülebildiğinden etkisi daha da ağırdır.

6. Proof Of Concept

Durum 1: Password reset broken logic

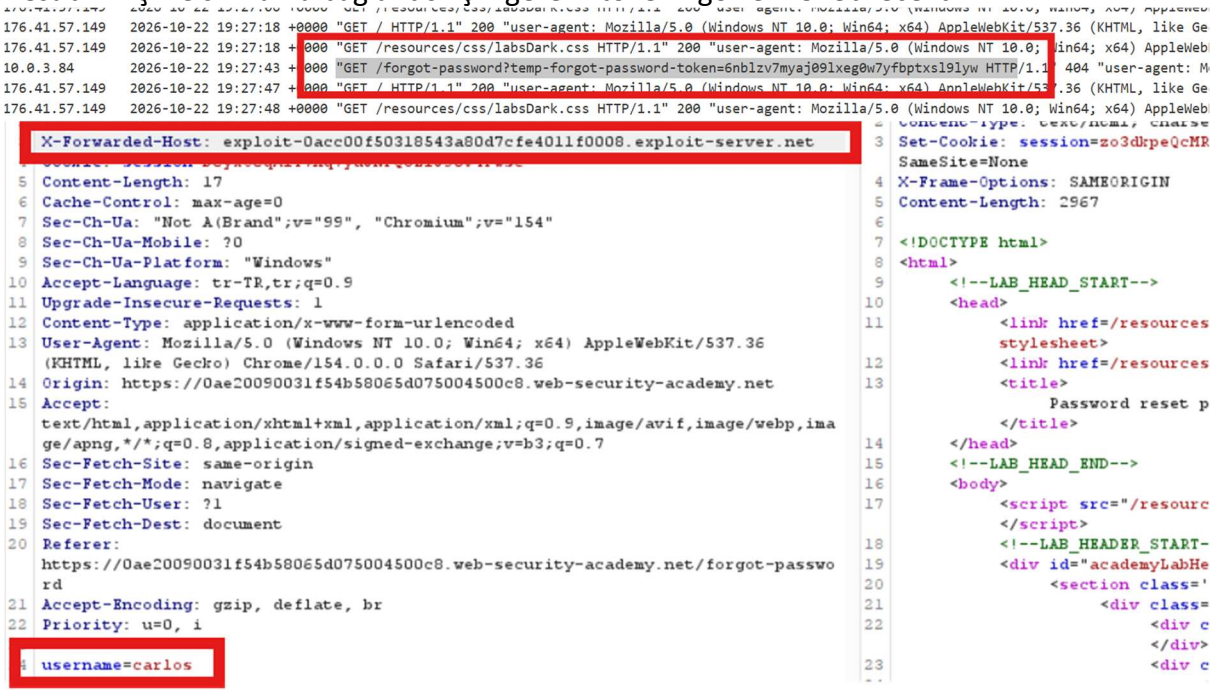
Hedef uygulamanın giriş formunda “Şifremi Unuttum” alanı görülmektedir. Verilen wiener kullanıcısı için bu özellik kullanıldığında ilgili hesabın mailine kurtarma bağlantısı gönderilmektedir. Bu bağlantı Burp Repeater’de incelendiğinde token, username, yeni şifre ve yeni şifreyi onayla parametreleri gözlemlenmektedir. Buradaki username parametresinde test edilmesi istenen “carlos” kullanıcısı kullanıldığında ilgili hesabın şifresi başarıyla değiştirilebilmekte ve hesaba giriş yapılabilmektedir.



Durum 2: Password reset poisoning via middleware

Hedef uygulamanın giriş formunda “Şifremi Unuttum” alanı görülmektedir. Verilen wiener kullanıcısı için bu özellik kullanıldığında ilgili hesabın mailine kurtarma bağlantısı gönderilmektedir. Bunlara ek olarak da verilen exploit server sayesinde erişim kayıtlarına bakılabilmektedir.

Şifremi unuttum özelliğini test edilmesi istenen carlos kullanıcısı için kullanılıp ilgili isteğe bu exploit server adresi yerleştirilip tekrar istek gönderildiğinde erişim kayıtlarına carlos hesabının şifre sıfırlama bağlantısı için gerekli token’ı gözlemlenebilecektir.



Şekil 1: Carlos için exploit server'a yönlendirme isteği



Şekil 2: Carlos şifre sıfırlama token

Bu token, şifre sıfırlama alanına gitmek için kullanılabilmektedir. Bu sayede şifre sıfırlanabilmekte ve hesab giriş yapılabilmektedir.

7. Çözüm Önerisi

Parola sıfırlama mekanizması aşağıdaki ilkelere göre yeniden tasarlanmalıdır. Sıfırlama token’ı tahmin edilemez ve tek kullanımlık olmalı, yalnızca kendisini talep eden kullanıcıya sıkıca bağlanmalı ve kısa bir süre sonra geçersiz kılınmalıdır. Hangi hesabın parolasının değiştirileceği, istekte gönderilen bir kullanıcı adı alanından değil, doğrudan token’ın ilişkilendirildiği kullanıcıdan belirlenmelidir. Ayrıca sıfırlama bağlantısındaki alan adı, Host ya da X-Forwarded-Host gibi istemcinin değiştirebileceği başlıklardan oluşturulmamalı; sunucuda sabit olarak tanımlı, güvenilen bir alan adı kullanılmalıdır.

8. Sonuç

Yapılan testler sonucunda, hedef uygulamanın parola sıfırlama mekanizmasının iki farklı biçimde güvenli olmadığı ve her iki durumda da kimliği doğrulanmamış bir saldırganın başka bir kullanıcının hesabını ele geçirebildiği doğrulanmıştır. Token'ın kullanıcıya sıkıca bağlanması ve sıfırlama bağlantısının yalnızca güvenilen bir alan adından oluşturulması ile zafiyetin giderilmesi önerilmektedir.